信息安全测评与风险评估

4.1 主机安全基线核查

授课教师：张玉



目录

CONTENTS

01 案例导入：一台服务器是怎么沦陷的

02 关键知识：主机基线的 7 个维度怎么查

03 动手实验：取证 + 判定

04 课内小结与下节预告

Part.01

案例导入——一台服务器是怎么沦陷的



案例导入——一台服务器的“沦陷”



案例素材

2024年，某制造企业的一台核心生产数据库服务器被勒索病毒加密，导致全厂停产72小时，直接经济损失超500万元。

事后调查发现

序号	问题	影响
1	操作系统未启用密码复杂度策略，管理员使用Admin@123	攻击者通过暴力破解获取管理员权限
2	未配置登录失败锁定策略	暴力破解无限制，攻击者可无限尝试
3	未关闭默认共享（C、Admin）	攻击者利用共享传播病毒
4	远程桌面（3389）直接对互联网开放	攻击面暴露
5	未安装防病毒软件	勒索病毒未被拦截
6	系统补丁超过6个月未更新	存在已知高危漏洞（如永恒之蓝）

素材0：案例事故调查表.docx

先想一想

1. 这 6 个问题，分别落在等保的哪个测评维度？
2. 如果事前做过一次基线核查，哪些损失本可以避免？
3. 换你来当测评师，最先查哪三项？为什么？

学习目标

学完这一节，你应该能做到：

01 理解

说清主机安全基线是什么，在 GB/T 22239 里对应哪些条款

02 掌握

在 Windows/Linux上找到口令、账户、审计、端口等配置项并判断合不合规

03 能够

在西普实验平台的真实主机上完成核查取证，留下可追溯的截图与回显

04 能够

录入核查结果、做出四档判定，导出规范的测评记录表

05 具备

针对不符合项，写出具体、能落地、带期限的整改建议

Part.02

关键知识——标准怎么说、怎么查



什么是主机安全基线？

安全基线（Security Baseline）是指信息系统在特定安全等级下，为保障系统安全运行所必须满足的最低安全配置标准。

本课重点

身份鉴别、访问控制（占比约60%），其他维度为补充。

维度	检查内容	标准依据
身份鉴别	口令复杂度、登录失败处理、远程管理加密	8.1.4.1
访问控制	账户权限、默认账户、最小权限原则	8.1.4.2
安全审计	审计策略、审计日志保护	8.1.4.3
入侵防范	最小安装、关闭高危端口、漏洞管理	8.1.4.4
恶意代码防范	防病毒软件安装、病毒库更新	8.1.4.5
数据完整性/保密性	数据传输/存储加密	8.1.4.7/8
数据备份恢复	备份策略	8.1.4.9
剩余信息保护	存储空间清除	8.1.4.10

身份鉴别核查

GB/T 22239 8.1.4.1

“应对登录的用户进行身份标识和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换。”

序号	检查项	Windows检查方法	Linux检查方法
1	密码复杂度策略	secpol.msc密码策略	/etc/security/pwquality.conf
2	密码最小长度	密码最小长度8位	minlen=8+
3	密码最长使用期限	密码最长使用期限90天	/etc/login.defsPASS_MAX_DAYS
4	密码历史	强制密码历史5个	/etc/security/opasswd
5	登录失败锁定	账户锁定策略5次失败锁定	pam_tally2/faillock
6	远程管理加密	使用RDP/SSH代替Telnet	禁用Telnet，使用SSH

身份鉴别怎么查——Windows 与 Linux 对照

Windows Server 配置核查（secpol.msc）

策略路径	策略名称	合规要求	检查结果
密码策略	密码必须符合复杂性要求	已启用	
密码策略	密码长度最小值	8个字符	
密码策略	密码最长使用期限	90天	
密码策略	强制密码历史	5个	
账户锁定策略	账户锁定阈值	5次	
账户锁定策略	账户锁定时间	15分钟	



素材2：Windows
配置核查检查表（快

Linux 配置核查（关键文件）

配置文件	参数	合规要求
/etc/login.defs	PASS_MAX_DAYS	90
/etc/login.defs	PASS_MIN_DAYS	1
/etc/login.defs	PASS_MIN_LEN	8
/etc/login.defs	PASS_WARN_AGE	7
/etc/ssh/sshd_config	PermitRootLogin	no（禁止root直接登录）
/etc/ssh/sshd_config	Protocol	2（仅使用SSHv2）



素材3：Linux配置
核查检查表（快速参

访问控制核查

GB/T 22239 8.1.4.2

“应对登录的用户分配账户和权限；应重命名或删除默认账户，修改默认账户的默认口令；应及时删除或停用多余的、过期的账户，避免共享账户的存在；应授予管理用户所需的最小权限，实现管理用户的权限分离。”

核心检查项

序号	检查项	合规要点
1	默认账户	Windows：Administrator是否重命名？Guest是否禁用？ Linux：root是否允许直接登录？
2	默认口令	是否修改了默认密码？（如：admin/admin、root/root）
3	多余账户	是否存在已离职人员账户？是否存在测试账户未清理？
4	共享账户	是否存在多人共用同一账户的情况？
5	最小权限	普通用户是否具有管理员权限？
6	权限分离	系统管理员、安全管理员、审计管理员是否分属不同账户？

常见问题

- ✗ Administrator账户未重命名
- ✗ Guest账户未禁用
- ✗ 存在已离职人员账户未删除
- ✗ 多人共用root/Administrator账户
- ✗ 普通用户具有sudo/管理员权限

安全审计核查

核心检查项

序号	Windows检查项	Linux检查项
1	审核策略是否启用？	rsyslog/auditd是否运行？
2	是否覆盖“成功”和“失败”事件？	audit.rules是否配置？
3	审计日志是否包含日期、时间、用户、事件？	日志是否包含必要信息？

Windows审核策略推荐

（等保三级）

审核策略	推荐设置
审核登录事件	成功，失败
审核账户登录事件	成功，失败
审核账户管理	成功，失败
审核目录服务访问	成功，失败
审核策略更改	成功，失败
审核系统事件	成功，失败

入侵防范核查

GB/T 22239 8.1.4.4 要求

“应遵循最小安装的原则，仅安装需要的组件和应用程序；应关闭不需要的系统服务、默认共享和高危端口；应能发现可能存在的已知漏洞，并在经过充分测试评估后，及时修补漏洞。”

核心检查项

序号	Windows检查项	Linux检查项
1	是否仅安装必要组件？	是否最小化安装？
2	是否关闭不需要的服务？	systemctllist-unit-files
3	默认共享（C$、Admin$、IPC$）是否关闭？	
4	高危端口是否关闭？（如135、137-139、445）	高危端口是否关闭？
5	是否定期进行漏洞扫描？	是否定期进行漏洞扫描？
6	系统补丁是否及时更新？	系统补丁是否及时更新？

常见高危端口风险

端口	服务	风险
135	RPC	远程执行漏洞
137-139	NetBIOS	信息泄露
445	SMB	勒索病毒传播（永恒之蓝）
23	Telnet	明文传输
21	FTP	明文传输
3389	RDP（远程桌面）	暴力破解攻击面

恶意代码防范核查

GB/T 22239 8.1.4.5：“应采用免受恶意代码攻击的技术措施或主动免疫可信验证机制及时识别入侵和病毒行为，并将其有效阻断。”

核心检查项

序号	检查项	合规要点
1	防病毒软件	是否安装防病毒软件？
2	病毒库更新	病毒库是否在有效期内？
3	定期查杀	是否配置定期全盘扫描？
4	实时防护	实时监控是否开启？
5	非Win系统	Linux是否需要防恶意代码措施？

常见问题

- ✗ 未安装防病毒软件
- ✗ 病毒库已过期
- ✗ 实时监控未开启
- ✗ 未定期全盘扫描

主机安全基线核查

维度	检查内容	标准依据
身份鉴别	口令复杂度、登录失败处理、远程管理加密	8.1.4.1
访问控制	账户权限、默认账户、最小权限原则	8.1.4.2
安全审计	审计策略、审计日志保护	8.1.4.3
入侵防范	最小安装、关闭高危端口、漏洞管理	8.1.4.4
恶意代码防范	防病毒软件安装、病毒库更新	8.1.4.5
数据完整性/保密性	数据传输/存储加密	8.1.4.7/8
数据备份恢复	备份策略	8.1.4.9
剩余信息保护	存储空间清除	8.1.4.10

Part.03

动手实验
——西普真机取证 + 判定



西普平台实验清单（Windows 选 1 + Linux 选 1）

编号	西普平台实验（真实目录）	你要查什么 · 覆盖条款
W1	Windows 系统安全评测 →Windows身份鉴别	口令复杂度、最小长度、有效期、历史、账户锁定阈值 8.1.4.1 a) / b)
W2	Windows 系统安全评测 →Windows安全审计	审核策略（登录/对象访问/策略变更，成功+失败）、安全日志留存 8.1.4.3 a)~c)
W3	Windows 系统安全评测 →Windows入侵防范	默认共享、Guest 与多余账户、非必要服务、445 等高危端口 8.1.4.4
W4	Windows 系统安全评测 →Windows访问控制	用户权限分配、关键目录 NTFS 权限（是否 Everyone 可写）8.1.4.2
L1	Linux 系统安全评测 →认证人工检查	login.defs、pwquality.conf、system-auth、空口令/弱口令账户 8.1.4.1 a) / b)
L2	Linux 系统安全评测 →安全审计漏洞人工检查	rsyslog / auditd 状态、/var/log/secure、audit 规则、日志留存 8.1.4.3 a)~c)
L3	Linux 系统安全评测 →系统人工检查	开放端口与非必要服务、系统补丁与已知漏洞 8.1.4.4
L4	Linux 系统安全评测 →账号人工检查	账户最小化、sudo 权限、关键文件权限 8.1.4.2 / 8.1.4.1 b)

本讲实验总览——流程主线（课内完成）

要素	内容
实验名称	主机安全基线核查——西普取证 + JSecProbe 判定
实验环境	西普实验平台 10.11.0.70（账号 = 11 位学号，初始密码 = 学号 + 1q2w）Win/Linux 虚拟机 + 判定（可借助AI）
流程主线	① 查：在虚拟机里定位配置项、跑命令，每条留 1 张截图 ② 判：对照基线做四档判定，写清"做到哪、差在哪"，再补整改建议 ③ 交：导出《主机安全测评记录表》，连同截图包课内提交至学习通

按照素材6和素材7完成实验

注意：每条核查项至少 1 张证据截图，截图文件名与“截图编号”一致（如 W1-01.png），与记录表一并提交，提交到学习通4.1实验

Part.04

课内小结与下节预告

把今天查出来的问题，写成别人能照着做的整改建议



职业提醒——你写下的每个字都要负责

技术合规 → 国家安全

每一台主机都是一个“节点”，连接起来就是“国家网络”

等保标准中的每一个配置项，都是无数安全事故的“血泪教训”总结

主机安全基线，是保障国家网络安全“最后一公里”的关键防线

客观准确 → 法治精神

测评不是“走过场”，更不是“做样子”

误判可能掩盖重大隐患，漏判可能导致重大事故

每一份测评记录表都是法律证据，必须真实、客观、可追溯

隐瞒问题和伪造数据，不仅要承担行政责任，还可能触犯刑法

职业使命 → 社会担当

你检查的不是“配置”，而是“社会责任”

一台服务器的配置漏洞，可能影响千万用户的信息安全

测评师的使命：用精准的检查，守护数字世界的安全底线

这就是信息安全从业者的“工匠精神”与“家国情怀”

– 知识点回顾

主机安全基线核查

1. **一、安全基线的定义**
   最低安全配置标准
2. **二、8.1.4.1 身份鉴别** 重点
   密码复杂度策略、密码长度与期限、登录失败锁定、远程管理加密
3. **三、8.1.4.2 访问控制** 重点
   默认账户处理、多余账户清理、最小权限原则、权限分离
4. **四、8.1.4.3 安全审计**
   审计策略启用、审计日志保护、日志定期备份
5. **五、8.1.4.4 入侵防范**
   最小安装原则、关闭高危端口、补丁管理
6. **六、8.1.4.5 恶意代码防范**
   防病毒软件、病毒库更新
7. **七、双环境实操**
   西普平台取证（界面/命令回显）+ JSecProbe 判定与导出记录表

课内任务已清——本节不留课后必做作业

课内 作业

实验报告（必须包含回显图片、记录表和实验收获）按照班级+学号+姓名+4.1实验命名后，提交学习通

下节 预告

4.2 网络设备配置核查：路由器、防火墙——上课前翻一眼案例即可

感谢观看

